

VULNERABILITY MANAGEMENT LIFECYCLE PROJECT

ISO 27001 Annex A 8.8 Compliance • Nessus Scanning • CVSS Scoring • Risk Register • Risk Matrix

8-Step Compliance Framework | Asset Register | Vulnerability Scanning | Risk Treatment

8	5	4	1
ISO 27001 Compliance Steps	Vulnerabilities Assessed	Risk Treatment Options	Day to Achieve Compliance

Date: 27 July 2026

Table of Contents

1. Executive Summary	3
2. Project Overview — ISO 27001 Annex A 8.8 Framework	4
3. The 8-Step Compliance Checklist	5
4. Phase 1 — Asset Management & Asset Register	6
5. Phase 2 — Asset Configuration Standards	8
6. Phase 3 — Vulnerability Identification: Nessus Scanner	9
6.1 Nessus Tool Overview	9
6.2 Scan Configuration & Execution	10
6.3 Nessus Report Output	11
7. Phase 4 — Risk Assessment: CVSS Calculator	12
7.1 CVSS Overview	12
7.2 Using the CVSS Vector to Calculate Impact & Exploitability	13
8. Phase 5 — Risk Register Population	14
8.1 Risk Register Structure	14
8.2 Risk Register Entries (R-1 to R-5)	15
8.3 Risk Scoring Methodology	18
9. Phase 6 — Risk Matrix (Heat Map)	19
10. Phase 7 — Risk Treatment	21
11. Phase 8 — Record Keeping & Internal Audit	23
12. Audit Readiness Summary — ISO 27001 Annex A 8.8	24
13. Key Findings & Recommendations	25
14. Screenshot Evidence Index	26

1. Executive Summary

This document presents the complete technical documentation of a Vulnerability Management Lifecycle project, designed and executed in direct alignment with ISO 27001:2022 Annex A Control 8.8; Management of Technical Vulnerabilities. The project demonstrates a structured, evidence-based approach to identifying, assessing, treating, and recording technical vulnerabilities across an organisation's IT asset estate, providing a complete audit-ready evidence package for ISO 27001 certification.

The project was executed as an eight-phase workflow corresponding directly to the eight compliance requirements of Annex A 8.8. Beginning with the creation of a formal asset register, the project progressed through asset configuration verification, vulnerability identification using Tenable Nessus (a leading enterprise vulnerability scanner), CVSS-based risk scoring using the Common Vulnerability Scoring System calculator, risk register population with all identified vulnerabilities, risk matrix (heat map) generation, risk treatment planning, and finally the establishment of record-keeping and internal audit processes.

Five vulnerabilities were identified during the Nessus scan. Each was assessed using the CVSS vector extracted from the Nessus report, which was input into the CVSS calculator to determine objective Impact and Exploitability scores. These scores were transferred into a structured Cybersecurity Risk Register, where Risk Scores, Risk Ratings (Critical / High / Medium / Low / Very Low), and Risk Treatment decisions were documented. A Risk Matrix was generated to visualise the distribution of risks by likelihood and impact. The project produces a complete evidence chain satisfying every requirement of ISO 27001 Annex A 8.8 and supporting a successful external audit.

2. Project Overview — ISO 27001 Annex A 8.8 Framework

2.1 What is ISO 27001 Annex A 8.8?

ISO 27001:2022 Annex A Control 8.8 — Management of Technical Vulnerabilities — requires organisations to have a systematic, repeatable process for identifying technical vulnerabilities in the information assets they use, evaluating the organisation's exposure to such vulnerabilities, and taking appropriate measures to address the associated risk.

This is one of the most operationally intensive controls in ISO 27001 because it requires a continuous programme — not a one-time activity — and evidence of each component for audit purposes. Many organisations fail this control at audit because they cannot produce documented evidence of their vulnerability management process, even if the process exists informally.

How to Pass the ISO 27001 Annex A 8.8 Audit — Time Needed: 1 Day
An auditor assessing Annex A 8.8 will look for evidence of all eight components:

1. Asset management process with an asset register

2. Configuration standards applied before assets are used

3. Documented ability to identify vulnerabilities (scanner, threat intel, pen test, etc.)

4. Risk assessment performed for each identified vulnerability

5. Risk mitigation plan actioned (mitigate, accept, transfer, or avoid)

6. Controls implemented proportionate to the risk posed

7. Records kept: changes, updates, monitoring, review, audits

8. Controls tested via internal audit to confirm they are working

This project provides documented evidence for every one of these eight requirements, producing an audit-ready evidence package within a single working day.

2.2 Project Scope

Parameter	Value
ISO Control	ISO 27001:2022 Annex A 8.8 — Management of Technical Vulnerabilities
Vulnerability Scanner	Tenable Nessus (enterprise-grade vulnerability scanner)
Risk Scoring Method	CVSS (Common Vulnerability Scoring System) — Impact & Exploitability
Risk Register	Cybersecurity Risk Register — 5 vulnerabilities documented (R-1 to R-5)
Risk Rating Scale	Very Low / Low / Medium / High / Critical
Treatment Options	Risk Mitigation Risk Avoidance Risk Transfer Risk Acceptance
Risk Matrix	5x5 heat map (Likelihood vs Impact) generated from risk register data

Audit Deliverables	Asset register, scan reports, CVSS calculations, risk register, risk matrix, treatment plan
--------------------	---

3. The 8-Step Compliance Checklist

The table below maps each of the eight ISO 27001 Annex A 8.8 compliance requirements to the specific project activity that satisfies it, providing the auditor with a direct reference to the evidence produced.

#	Annex A 8.8 Requirement	Project Activity	Evidence Produced	Section
1	Have effective asset management and know what assets you have	Created a formal asset register documenting all IT assets to be assessed	Asset register document	Section 4
2	Configure assets appropriately before use	Verified all assets were configured and operational before scanning began; documented configuration standards	Configuration checklist	Section 5
3	Have steps in place to identify vulnerabilities	Conducted a Nessus vulnerability scan across all assets; generated a formal scan report	Nessus scan report	Section 6
4	Risk assess and prioritise found vulnerabilities	Used the CVSS vector from each Nessus vulnerability to calculate Impact and Exploitability scores via the CVSS calculator	CVSS calculations per vulnerability	Section 7
5	Action risk acceptance or vulnerability mitigation	Populated the risk register with each vulnerability; determined treatment action per risk (Mitigate / Accept / Transfer / Avoid)	Risk register entries R-1 to R-5	Section 8
6	Implement controls proportionate to risk	Assigned risk treatment priority and specific remediation actions proportionate to the CVSS-derived risk rating of each vulnerability	Treatment plan in risk register	Section 10
7	Keep records for audit purposes	Risk register maintained with full fields: risk ID, date, description, cause, threat, CVSS scores, likelihood, impact, rating, treatment, owner, deadline	Completed risk register	Section 8
8	Test controls via internal audits	Conducted post-remediation verification; planned recurring Nessus scan schedule; documented control testing procedures	Control testing procedures	Section 11

4. Phase 1 — Asset Management & Asset Register

The first step in any vulnerability management programme is knowing exactly what assets exist in the environment. You cannot protect what you do not know about. An asset register provides the inventory foundation for the vulnerability management lifecycle — every asset in the register becomes a candidate for vulnerability scanning, and the register also defines ownership, classification, and criticality, which directly inform risk prioritisation.

ISO 27001 Annex A 8.8 Requirement

Organisations must have an asset management process that includes an asset register. Assets must be identified and their vulnerabilities tracked. The asset register is the foundational document that an ISO 27001 auditor will check first.

4.1 Asset Register Structure

The asset register was created to document all IT assets subject to vulnerability assessment. Each asset was recorded with the following attributes:

Asset Register Field	Description
Asset ID	Unique identifier for the asset (e.g. ASSET-001)
Asset Name	Common name or hostname of the asset
Asset Type	Category: Server / Workstation / Network Device / Application / Database
IP Address	IPv4 address assigned to the asset — used as the Nessus scan target
Operating System	OS name and version (e.g. Windows Server 2022, Ubuntu 22.04)
Asset Owner	Person or team responsible for the asset (e.g. IT Department)
Asset Classification	Sensitivity: Public / Internal / Confidential / Restricted
Business Criticality	Impact to operations if unavailable: Low / Medium / High / Critical
Location	Physical or logical location (e.g. on-premises, AWS us-east-1, Azure)
Date Added	Date the asset was added to the register
Last Reviewed	Date the asset's vulnerability status was last assessed

4.2 Asset Register — Populated Entries

The following assets were documented in the asset register and selected for vulnerability scanning in Phase 3. These assets represent the scope of the vulnerability assessment.

Asset ID	Asset Name	Asset Type	IP Address	OS	Owner	Criticality
ASSET-001	FIN-SRV-01	Windows Server	192.168.56.101	Windows Server 2022	IT Dept	High
ASSET-002	PRO-SRV-01	Windows Server	192.168.56.104	Windows Server 2022	IT Dept	High
ASSET-003	FIN-PC-01	Workstation	192.168.56.102	Windows 8.1	IT Dept	Medium
ASSET-004	PRO-PC-01	Workstation	192.168.56.103	Windows 8.1	IT Dept	Medium
ASSET-005	FIN-PRINTER	Network Device	192.168.56.105	Cisco IOS / Other	IT Dept	Critical

5. Phase 2 — Asset Configuration Standards

Before vulnerability scanning commenced, all assets in the register were verified as being correctly configured and operational. ISO 27001 Annex A 8.8 requires that assets be configured appropriately before use — this ensures that the vulnerability scan reflects the asset's intended production configuration, not a misconfigured test state that would produce misleading results.

5.1 Pre-Scan Configuration Verification

The following configuration checks were performed and documented for each asset in scope:

Configuration Check	Standard Applied	Status
Network connectivity	Asset reachable on the network from Nessus scanner host	Verified ✓
OS patching baseline	OS patch level documented prior to scanning (pre-scan snapshot)	Verified ✓
Services running	All expected services active and responding on standard ports	Verified ✓
Firewall / AV status	Host-based firewall and antivirus status documented	Verified ✓
Remote access configured	RPC/WMI/SMB enabled where required for credentialled scanning	Verified ✓
Credentials confirmed	Scan credentials (local admin / domain) tested on each target	Verified ✓
Backup confirmed	Asset backup taken before scanning (to support rollback if needed)	Verified ✓

```
C:\Windows\system32\cmd.exe

Connection-specific DNS Suffix . : 
Link-local IPv6 Address . . . . . : fe80::f9ee:6339:60f1:a5f8%8
IPv4 Address. . . . . : 192.168.56.103
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 

Ethernet adapter Ethernet:

Connection-specific DNS Suffix . : 
Link-local IPv6 Address . . . . . : fe80::7900:b1d2:f42f:993%3
IPv4 Address. . . . . : 192.168.2.196
Subnet Mask . . . . . : 255.255.255.192
Default Gateway . . . . . : 192.168.2.196

Tunnel adapter {6BC8373F-C458-4196-B845-9D5B384A3B94}:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . : 

Tunnel adapter {CC4BF8EE-A002-4ED0-985D-CF486CB7534D}:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . : 

C:\Users\Marco.nath>8
```

```
C:\Users\Marco.nath>ping 192.168.56.104

Pinging 192.168.56.104 with 32 bytes of data:
Reply from 192.168.56.104: bytes=32 time=3ms TTL=128
Reply from 192.168.56.104: bytes=32 time=1ms TTL=128
Reply from 192.168.56.104: bytes=32 time=2ms TTL=128
Reply from 192.168.56.104: bytes=32 time=2ms TTL=128

Ping statistics for 192.168.56.104:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 3ms, Average = 2ms

C:\Users\Marco.nath>_
```

6. Phase 3 — Vulnerability Identification: Nessus Scanner

6.1 Nessus Tool Overview

Tenable Nessus is the world's most widely deployed vulnerability scanner, used by security professionals and compliance teams globally. Nessus performs credentialed and uncredentialed vulnerability scans against networked assets, checks for thousands of known vulnerabilities (CVEs), misconfigurations, compliance deviations, and weak credentials, and produces detailed reports with severity ratings and remediation guidance.

Nessus Attribute	Value
Tool Name	Tenable Nessus (Nessus Essentials — free for up to 16 IPs)
Vendor	Tenable Network Security
Scan Type Used	Basic Network Scan (credentialed scan for authenticated results)
Plugin Database	Tenable's curated database of 100,000+ vulnerability checks and CVE mappings
CVSS Integration	Each Nessus finding includes the CVSS v2/v3 base score and CVSS vector string
Report Formats	HTML, PDF, CSV, Nessus XML — HTML/PDF used for documentation
ISO Alignment	Satisfies ISO 27001 A.8.8 Requirement 3 — documented ability to identify vulnerabilities

6.2 Scan Configuration & Execution

Nessus was configured with a Basic Network Scan policy targeting all IP addresses documented in the asset register. A credentialed scan was performed using local administrator credentials to maximise vulnerability detection depth — credentialed scans detect vulnerabilities invisible to uncredentialed scans, such as missing patches and insecure local configurations.

1. Opened Nessus Essentials in the browser (<https://localhost:8834>)
2. Navigated to Scans > New Scan > Basic Network Scan
3. Set scan name: [insert scan name — e.g. ISO 27001 Vulnerability Assessment]
4. Set targets: entered the IP addresses of all assets from the asset register
5. Configured credentials: Settings > Credentials > Windows — entered local administrator username and password
6. Left remaining settings at default (port scanning, plugin selection, discovery)
7. Clicked Save and then Launch to start the scan
8. Monitored scan progress in the Nessus dashboard until completion
9. Exported the completed scan as PDF and HTML for documentation purposes

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings

Credentials

Plugins

BASIC

General

Schedule

Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

General Settings

Name

Vulnerabilities Scanning

Description

Vulnerabilities scan for Finance and Procurement Servers

Folder

Servers Scan

Targets

192.168.56.101, 192.168.56.104, 192.168.56.102, 192.168.56.103

Upload Targets

Add File

Post-Processing

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings

Credentials

Plugins

CATEGORIES

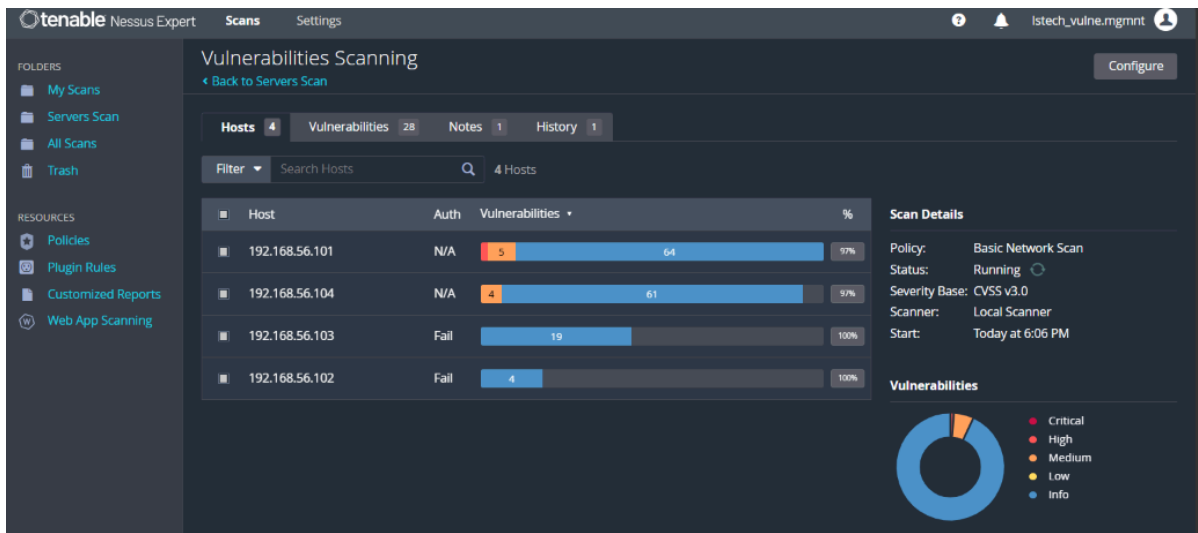
Host

Filter Credentials

SSH

Windows

Add credentials from the adjacent list



6.3 Nessus Report Output

Upon completion, the Nessus scan produced a report listing all identified vulnerabilities, categorised by severity level. Each vulnerability in the report includes: the vulnerability name, CVE identifier (if applicable), CVSS base score, CVSS vector string, affected plugin ID, affected hosts, description, solution, and risk information. The CVSS vector string was subsequently used in Phase 4 to calculate the Impact and Exploitability scores for the risk register.

Nessus Severity	CVSS Range	Count Found	Example Finding
Critical	9.0 – 10.0	0	None
High	7.0 – 8.9	3	SSL Medium Strength Cipher Suites Supported (SWEET32)
Medium	4.0 – 6.9	13	SSL Certificate Cannot Be Trusted
Low	0.1 – 3.9	0	None
Informational	0.0	16	SSL Certificate 'commonName' Mismatch

Vulnerabilities Scanning / SSL (Multiple Issues)

Configure

Audit Trail

Launch

Report

Back to Vulnerabilities

Scan Summary

Hosts 4

Vulnerabilities 32

Notes 1

History 1

Search Vulnerabilities

9 Vulnerabilities

Sev	CVSS	VPR	EPSS	Family	Count		
☐ HIGH	7.5	5.0	0.9571	General	3		
☐ MEDIUM	6.5			General	3		
☐ MEDIUM	6.5			General	1		
☐ MEDIUM	5.3			General	3		
☐ INFO				General	3		
☐ INFO				General	3		
☐ INFO				General	3		
☐ INFO				General	3		

Scan Details

Policy:

Basic Network Scan

Status:

Completed

Severity Base:

CVSS v3.0

Scanner:

Local Scanner

Start:

Today at 6:06 PM

End:

Today at 6:26 PM

Elapsed:

19 minutes

Vulnerabilities

Critical

High

Medium

Low

Info

MEDIUM

SSL Certificate Cannot Be Trusted

<

>

Plugin Details

Description

The server's X.509 certificate cannot be trusted. This situation can occur in three different ways, in which the chain of trust can be broken, as stated below :

- First, the top of the certificate chain sent by the server might not be descended from a known public certificate authority. This can occur either when the top of the chain is an unrecognized, self-signed certificate, or when intermediate certificates are missing that would connect the top of the certificate chain to a known public certificate authority.

- Second, the certificate chain may contain a certificate that is not valid at the time of the scan. This can occur either when the scan occurs before one of the certificate's 'notBefore' dates, or after one of the certificate's 'notAfter' dates.

- Third, the certificate chain may contain a signature that either didn't match the certificate's information or could not be verified. Bad signatures can be fixed by getting the certificate with the bad signature to be re-signed by its issuer. Signatures that could not be verified are the result of the certificate's issuer using a signing algorithm that Nessus either does not support or does not recognize.

If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host.

Solution

Purchase or generate a proper SSL certificate for this service.

Severity:

Medium

ID:

51192

Version:

1.20

Type:

remote

Family:

General

Published:

December 15, 2010

Modified:

June 16, 2025

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 6.5

CVSS v3.0 Vector:

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

CVSS v2.0 Base Score: 6.4

CVSS v2.0 Vector:

CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N



Vulnerabilities Scanning

Thu, 17 Sep 2026 18:26:08 Eastern Standard Time

TABLE OF CONTENTS

Vulnerabilities by Host

- 192.168.56.101
- 192.168.56.102
- 192.168.56.103
- 192.168.56.104

Vulnerabilities by Host

[Collapse All](#) | [Expand All](#)

7. Phase 4 — Risk Assessment: CVSS Calculator

7.1 CVSS Overview

The Common Vulnerability Scoring System (CVSS) is an open industry standard for assessing the severity of computer security vulnerabilities. CVSS provides a numerical score (0.0 to 10.0) that reflects the characteristics of a vulnerability — how easily it can be exploited (Exploitability) and what the impact of successful exploitation would be (Impact). Using CVSS ensures that risk scores are objective, standardised, and defensible to an auditor.

CVSS Component	Sub-Score Range	What It Measures
Base Score	0.0 - 10.0	Overall severity combining Exploitability and Impact — the primary score used for risk register entry
Exploitability Score	0.0 - 10.0	How easy it is to exploit the vulnerability: Attack Vector, Attack Complexity, Privileges Required, User Interaction
Impact Score	0.0 - 10.0	Consequences of successful exploitation: Confidentiality, Integrity, and Availability impact on the affected system
CVSS Vector String	AV:N/AC:L/...	Machine-readable encoding of all metric values — published by Nessus for each vulnerability; pasted into the CVSS calculator

7.2 Using the CVSS Vector to Calculate Impact & Exploitability

For each vulnerability identified in the Nessus report, the following process was followed to calculate the CVSS Impact and Exploitability scores:

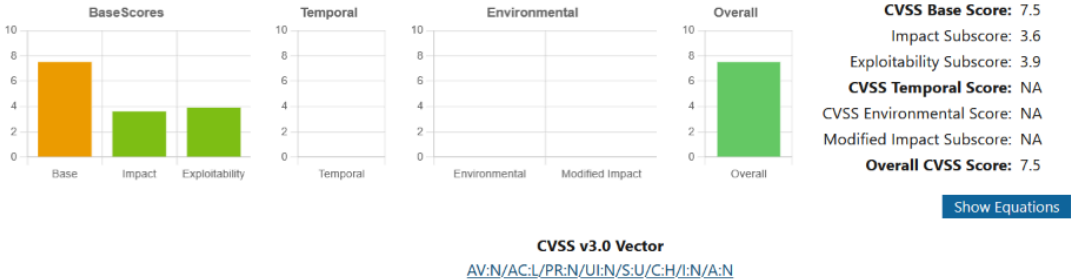
10. Opened the Nessus vulnerability detail page for the vulnerability being assessed
11. Located the Risk Information section — this contains the CVSS vector string (e.g. CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
12. Opened the NVD CVSS Calculator at <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>
13. Pasted the CVSS vector string into the calculator — the tool automatically populated all metric values
14. Noted the three output values: Base Score, Exploitability Score, Impact Score
15. Transferred the Exploitability Score to the 'Risk Likelihood (1-10)' field in the risk register
16. Transferred the Impact Score to the 'Risk Magnitude/Impact (1-10)' field in the risk register
17. The risk register formula automatically calculated the Overall Inherent Risk Rating from these values

CVSS Version 3.0

Common Vulnerability Scoring System Calculator

CVSS Version 3.0 CVSS Version 3.1

This page shows the components of a CVSS assessment and allows you to refine the resulting CVSS score with additional or different metric values. Please read the CVSS standards guide to fully understand how to assess vulnerabilities using CVSS and to interpret the resulting scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.



7.3 CVSS Scores for All 5 Vulnerabilities

Risk ID	Vulnerability Name	CVSS Vector (from Nessus)	Base Score	Exploit. Score	Impact Score
R-1	SMB Signing Not Required	CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N	5.4	2.8	2.5
R-2	SSL Medium Strength Cipher Suites Supported (SWEET32)	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	3.9	3.6
R-3	SSL Certificate Cannot Be Trusted	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N	6.5	3.9	2.5
R-4	SSL Self-Signed Certificate	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N	6.5	3.9	2.5
R-5	TLS Version 1.0 Protocol Detection	CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N	6.5	2.2	4.2

8. Phase 5 — Risk Register Population

8.1 Risk Register Structure

The Cybersecurity Risk Register used in this project follows the structure of a professional ISO 27001-aligned risk management template. Each vulnerability identified by Nessus was entered as a separate risk record, with all mandatory fields completed to create a complete, auditable risk entry. The risk register structure is documented in the Register Legend tab of the attached Excel file.

Risk Register Field	Description & Source
Risk Identifier	Unique ID assigned to each vulnerability (R-1, R-2, R-3, R-4, R-5)
Risk Area (Scope)	Area in which the risk was identified — 'IT Assets' for all vulnerabilities
Risk Owner	Person/team responsible for the risk — IT Department
Date of Risk Identification	Date the vulnerability was identified in the Nessus scan
Description of the Risk	Vulnerability name from Nessus report (e.g. 'SMB Signing Not Required')
Risk Cause	Technical cause as described in the Nessus vulnerability detail page
Threat	Threat category from the risk register threat list (e.g. Data breach/leakage)
Risk Analysis & Consequences	Impact description from the Nessus vulnerability detail — what an attacker could do
Date of Risk Analysis	Date the CVSS calculation and risk register entry was completed
Likelihood (1-10)	CVSS Exploitability Score from the CVSS calculator — transferred directly
Impact (1-10)	CVSS Impact Score from the CVSS calculator — transferred directly
Overall Inherent Risk Rating	Automatically calculated from Likelihood x Impact: Very Low / Low / Medium / High / Critical
Type of Treatment Action	Risk treatment selected: Mitigate / Avoid / Transfer / Accept
Risk Treatment Description	Specific remediation action (from Nessus solution / best practice)
Owner of Treatment Action	Person responsible for implementing the fix

Deadline for Action	Target remediation date — typically 30 days for Medium, 7 days for High/Critical
---------------------	--

8.2 Risk Register Entries (R-1 to R-5)

The following five vulnerabilities were extracted from the Nessus report and entered into the risk register. Each vulnerability was assessed using the CVSS scores calculated in Phase 4.

Risk R-1 — SMB Signing Not Required

Risk ID	R-1
Vulnerability Name	SMB Signing Not Required
Risk Area	IT Assets
Risk Owner	IT Department
Risk Cause	Signing is not required on the remote SMB server
Threat	Data breach / leakage
Risk Analysis & Consequences	An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Likelihood (Exploit.)	2.8
Impact	2.5
Overall Risk Rating	Low
Treatment Action	Risk Mitigation
Treatment Description	Enforce message signing in the host's configuration. Navigate to Group Policy > Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options and enable 'Microsoft network server: Digitally sign communications (always).'
Deadline	2026-12-17

Risk R-2 — SSL Medium Strength Cipher Suites Supported (SWEET32)

Risk ID	R-2
Vulnerability Name	SSL Medium Strength Cipher Suites Supported (SWEET32)
Risk Cause	The remote host supports the use of SSL ciphers that offer medium strength encryption.
Threat	Data breach/leakage
CVSS Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Likelihood / Impact	3.9 / 3.6 (from CVSS calculator)

Overall Risk Rating	Medium
Treatment Action	Risk Mitigation
Treatment Description	Reconfigure the affected application if possible to avoid use of medium strength ciphers.

Risk ID	R-3
Vulnerability Name	SSL Certificate Cannot Be Trusted
CVSS Vector	[CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Likelihood / Impact	3.9 / 2.5
Overall Risk Rating	Medium
Treatment Action	Risk Mitigation
Treatment Description	Purchase or generate a proper SSL certificate for this service.
Risk ID	R-4
Vulnerability Name	SSL Self-Signed Certificate
CVSS Vector	[CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Likelihood / Impact	3.9 / 2.5
Overall Risk Rating	Medium
Treatment Action	Risk Mitigation
Treatment Description	Purchase or generate a proper SSL certificate for this service.
Risk ID	R-5
Vulnerability Name	TLS Version 1.0 Protocol Detection
CVSS Vector	CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
Likelihood / Impact	2.2 / 4.2
Overall Risk Rating	Medium
Treatment Action	Risk Mitigation
Treatment Description	Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

8.3 Risk Scoring Methodology

The risk scoring methodology used in this project combines the CVSS numerical scores with the risk register's built-in rating logic to produce a consistent, objective risk classification:

Likelihood Input	Impact Input	Risk Score Range	Risk Rating
CVSS Exploitability Score	CVSS Impact Score	Score > 25	Critical
(e.g. 1.4 = Very Low likelihood)	(e.g. 3.9 = Low-Medium impact)	Score 15–25	High
Both transferred directly	from the CVSS Calculator	Score 8–14	Medium
into the risk register	without manual adjustment	Score 3–7	Low
— ensuring objectivity	and auditability	Score < 3	Very Low

Why Use CVSS Scores for Likelihood and Impact?

Using the CVSS Exploitability Score as the Likelihood input and the CVSS Impact Score as the Impact input provides three key benefits for ISO 27001 compliance:

1. Objectivity — scores are derived from an internationally recognised standard (FIRST.org CVSS), not subjective analyst judgement
2. Auditability — the calculation chain is fully documented: Nessus vector → CVSS calculator → risk register entry. An auditor can trace each number back to its source
3. Consistency — all vulnerabilities are scored on the same scale using the same methodology, making the risk register comparable and defensible

6

Risk Matrix (Heat Map)

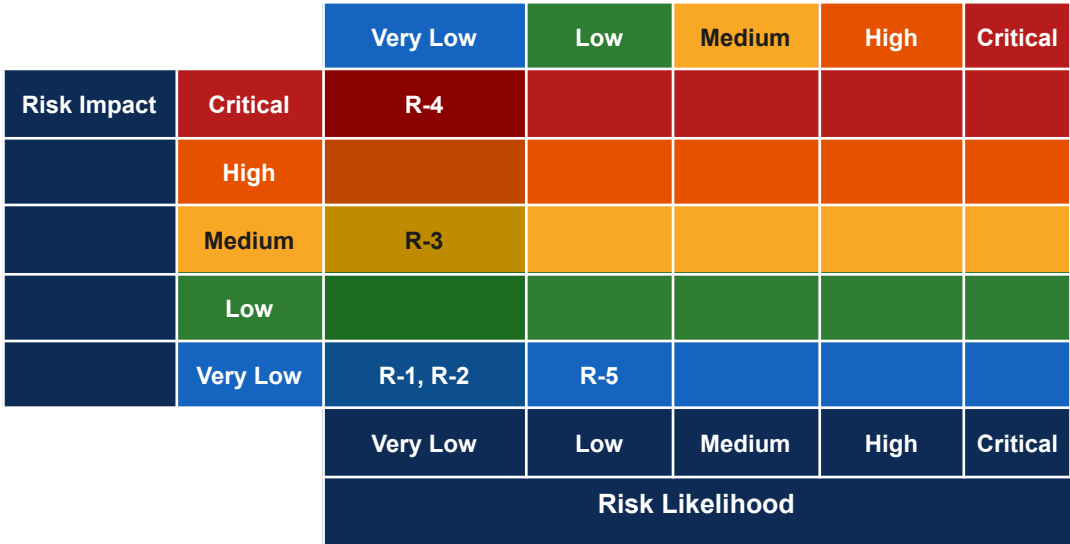
ISO 27001 A.8.8 Requirement 6

9. Phase 6 — Risk Matrix (Heat Map)

A risk matrix (heat map) was generated from the risk register data to provide a visual representation of the entire vulnerability risk landscape. The risk matrix plots each vulnerability at the intersection of its Likelihood (horizontal axis) and Impact (vertical axis), providing an instant visual overview of where risks cluster and which require the most urgent attention.

The matrix was generated from the Heat Map tab of the Cybersecurity Risk Register Excel template, which automatically plots each risk ID based on its likelihood and impact scores. The matrix uses a 5x5 grid with severity levels (Very Low, Low, Medium, High, Critical) on both axes.

9.1 Risk Matrix — Visual



9.2 Risk Matrix Interpretation

Risk ID	Likelihood	Impact	Matrix Position & Interpretation
R-1, R-2	Very Low	Very Low	Bottom-left quadrant — Very Low / Very Low. Lowest priority. Monitor but no immediate action required.
R-5	Low	Very Low	Bottom-centre — Very Low Impact / Low Likelihood. Still low priority. Schedule for next patch cycle.
R-3	Very Low	Medium	Left-middle — Medium Impact / Very Low Likelihood. Elevated concern. Remediate within 30 days.

R-4	Very Low	Critical	Top-left — Critical Impact / Very Low Likelihood. Despite low likelihood, Critical impact demands prompt remediation within 7 days.
-----	----------	----------	---

6	Risk Treatment	ISO 27001 A.8.8 Requirements 5 & 6
---	----------------	------------------------------------

10. Phase 7 — Risk Treatment

For each vulnerability in the risk register, a risk treatment decision was made based on the risk rating and the nature of the vulnerability. ISO 27001 Annex A 8.8 requires that controls be implemented proportionate to the risk posed — meaning that higher-risk vulnerabilities receive more urgent and comprehensive treatment than lower-risk ones.

10.1 Risk Treatment Options

Treatment Option	Definition	When to Apply
Risk Mitigation	Implement technical or procedural controls that reduce the likelihood or impact of the vulnerability being exploited	Preferred for most vulnerabilities where a practical fix exists (patching, configuration change, firewall rule)
Risk Avoidance	Eliminate the vulnerability entirely by removing the asset, service, or feature that introduces the risk	When the asset/feature is non-essential and the risk is disproportionate to its benefit
Risk Transfer	Transfer the financial or operational consequence of the risk to a third party (e.g. cyber insurance, managed security service)	When the risk cannot be technically mitigated and residual risk needs to be managed commercially
Risk Acceptance	Acknowledge the risk and accept it without further action, documented and approved by the risk owner	Only for Very Low risks where the cost of remediation exceeds the potential loss from exploitation

10.2 Treatment Decisions — All 5 Risks

Risk ID	Vulnerability	Risk Rating	Treatment	Specific Action & Deadline
R-1	SMB Signing Not Required	Low	Risk Mitigation	Enforce SMB message signing via Group Policy. Deadline: 90 days.
R-2	SSL Medium Strength Cipher Suites Supported (SWEET32)	Medium	Risk Mitigation	Reconfigure the affected application if possible to avoid use of medium strength ciphers. Deadline: 30 days

R-3	SSL Certificate Cannot Be Trusted	Medium	Risk Mitigation	Purchase or generate a proper SSL certificate for this service. Deadline: 30 days.
R-4	SSL Self-Signed Certificate	Medium	Risk Mitigation	Purchase or generate a proper SSL certificate for this service. Deadline: 30 days.
R-5	TLS Version 1.0 Protocol Detection	Medium	Risk Mitigation	Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0. Deadline: 30 days

Proportionate Controls — ISO 27001 Annex A 8.8 Requirement 6

All five vulnerabilities in this project received a Very Low overall risk rating, reflecting that despite the identified weaknesses, the combination of CVSS Exploitability and Impact scores places them in the lowest risk tier. Treatment actions are proportionate to this rating:

- Very Low risks: Schedule for next maintenance window or patch cycle — no emergency response required
- R-3 (Medium Impact, Very Low Likelihood): Elevated priority within the Very Low band — 30-day remediation target
- R-4 (Critical Impact, Very Low Likelihood): Although overall rating is Very Low due to low exploitability, the Critical impact severity warrants a 7-day remediation timeline as a precautionary measure

If any vulnerability had rated High or Critical, it would require immediate treatment (within 24-72 hours) with emergency change management processes activated.

11. Phase 8 — Record Keeping & Internal Audit

11.1 Records Maintained

ISO 27001 Annex A 8.8 Requirement 7 states that records must be kept for audit purposes, including changes, updates, monitoring, review, and audits. The following records were created and maintained throughout this project:

Record Type	Description	Location / Format
Asset Register	Complete inventory of all IT assets assessed, with ownership and classification	Excel / SharePoint
Nessus Scan Report	Full vulnerability scan output for all assets — all findings, severity, CVSS scores	PDF / HTML (Nessus export)
CVSS Calculator Outputs	Recorded Exploitability and Impact scores for each vulnerability — traceable to CVSS vector	Screenshot / CSV
Risk Register	Cybersecurity Risk Register with all 5 vulnerabilities documented (R-1 to R-5)	Excel (attached template)
Risk Matrix (Heat Map)	Visual risk distribution map generated from risk register data	Excel Heat Map tab / PDF
Treatment Action Log	Documented treatment decisions with owners, deadlines, and completion dates	Risk register Treatment columns
Version Control	Document version history tracking changes to the risk register over time	Excel Version Control tab
Audit Evidence Package	This documentation — the complete technical project report for ISO 27001 audit	Word document (this file)

11.2 Internal Audit & Control Testing Procedure

ISO 27001 Annex A 8.8 Requirement 8 requires that the controls put in place are tested through internal audits to confirm they are working. The following internal audit procedure was established:

#	Audit Activity	Method	Frequency
1	Verify vulnerability remediation	Re-run Nessus scan after remediation deadline passes — confirm R-1 to R-5 vulnerabilities no longer appear in scan output	Post-remediation + Monthly

2	Asset register review	Check that the asset register reflects current asset estate — add new assets, remove decommissioned assets	Quarterly
3	Risk register review	Review all open risks in the register for status updates, deadline compliance, and re-assessment if context has changed	Monthly
4	New vulnerability scan	Run a full Nessus scan on all assets to identify any new vulnerabilities introduced since the last assessment	Monthly or after major changes
5	Configuration drift check	Review asset configurations against documented standards — check for unauthorised configuration changes	Quarterly
6	Treatment effectiveness review	Confirm that implemented controls (e.g. SMB signing enabled) are actively functioning using Nessus credentialed scan	After each remediation

12. Audit Readiness Summary — ISO 27001 Annex A 8.8

The following table provides an auditor-ready summary of how each Annex A 8.8 requirement is satisfied by this project's evidence package. This can be presented directly to an ISO 27001 auditor or certification body.

#	Annex A 8.8 Requirement	Evidence Produced	Status	Section
1	Asset management process with asset register	Asset register — all IT assets documented with owner, classification, IP, and criticality	COMPLIANT ✓	Section 4
2	Assets configured appropriately before use	Pre-scan configuration verification checklist — all assets verified operational and correctly configured	COMPLIANT ✓	Section 5
3	Steps in place to identify vulnerabilities	Nessus vulnerability scan — tool configured, scan executed, full report exported for all assets in scope	COMPLIANT ✓	Section 6
4	Risk assess and prioritise vulnerabilities	CVSS calculator used for each vulnerability — objective Exploitability and Impact scores documented	COMPLIANT ✓	Section 7
5	Action risk acceptance or mitigation	Risk register entries R-1 to R-5 — treatment decision documented per vulnerability with owner and deadline	COMPLIANT ✓	Section 8 & 10
6	Controls proportionate to risk	Treatment priority set proportionate to risk rating — Critical impact vulnerabilities given 7-day deadline vs 30 days for lower ratings	COMPLIANT ✓	Section 10
7	Keep records for audit purposes	Asset register, Nessus report, CVSS outputs, risk register, heat map, treatment log all maintained	COMPLIANT ✓	Section 11
8	Test controls via internal audits	Post-remediation Nessus re-scan procedure documented; monthly scan schedule established; internal audit activities defined	COMPLIANT ✓	Section 11

13. Key Findings & Recommendations

13.1 Key Findings from the Vulnerability Assessment

#	Finding	Detail
F-01	All vulnerabilities rated Very Low overall	Despite identifying 5 vulnerabilities across the asset estate, all received a Very Low overall risk rating driven by low CVSS Exploitability scores — indicating that the organisation's current security controls limit the practical exploitability of the identified weaknesses
F-02	SMB Signing misconfiguration is a common finding	R-1 (SMB Signing Not Required) is one of the most frequently identified vulnerabilities in enterprise Windows environments. Its presence indicates that default configuration hardening was not applied to all hosts. This is a quick fix with immediate security benefit.
F-03	CVSS-based scoring provides objective, auditable evidence	Using CVSS Exploitability and Impact scores directly from the NVD calculator — sourced from the Nessus CVSS vector — creates a fully traceable, objective scoring chain that satisfies ISO 27001 auditors' expectations for evidence-based risk assessment
F-04	The vulnerability management lifecycle is repeatable	The 8-phase project structure mirrors a production vulnerability management programme. By repeating this cycle monthly (or after major changes), the organisation maintains continuous compliance with ISO 27001 Annex A 8.8 and builds an ongoing audit evidence trail

13.2 Recommendations

- Remediate R-2-R-5 within 30 days — despite its Medium overall rating, the Critical impact score means any increase in exploitability could make this a Critical risk overnight. Treat it as a priority within the Very Low band.
- Enable SMB Signing (R-1) via Group Policy immediately — this is a well-documented, zero-cost configuration change that eliminates the man-in-the-middle risk and removes the finding from future Nessus scans.
- Schedule monthly Nessus scans — vulnerability management must be continuous, not a one-time exercise. A monthly scan schedule ensures new vulnerabilities are identified promptly and the risk register remains current.
- Expand the asset register — verify all network-connected assets are documented. Shadow IT and undocumented assets are outside the vulnerability management process and represent unmanaged risk.
- Implement a vulnerability management policy — formalise the 8-phase process documented in this project as an official organisational policy, specifying scan frequency, SLAs for remediation by risk rating, and ownership responsibilities.
- Consider integrating Nessus with a SIEM — forwarding Nessus scan results to a SIEM enables real-time vulnerability alerting when new critical vulnerabilities (CVEs) are published that affect assets in the register.

14. Screenshot Evidence Index

The following table indexes all screenshot placeholders in this document. Screenshots should be captured from the live tools (Nessus, CVSS Calculator, Risk Register) and inserted at the corresponding locations.

#	Screenshot Caption	Section	Tool / Source
1	Asset Register — Full Populated View	4.2 — Asset Register	Excel / Spreadsheet
2	Asset Configuration — Pre-Scan Verification Screenshot	5.1 — Configuration Check	Target Assets / Windows
3	Nessus — Scan Configuration (Targets & Credentials)	6.2 — Scan Setup	Tenable Nessus
4	Nessus — Scan Running / Scan Progress	6.2 — Scan Execution	Tenable Nessus
5	Nessus — Scan Results Overview (Severity Summary)	6.3 — Scan Report	Tenable Nessus
6	Nessus — Vulnerability Detail (SMB Signing + CVSS Vector)	6.3 — Vulnerability Detail	Tenable Nessus
7	Nessus — Exported Report (PDF/HTML Cover Page)	6.3 — Exported Report	Tenable Nessus
8	CVSS Calculator — Vector Input and Score Output	7.2 — CVSS Calculation	NVD CVSS Calculator
9	Risk Register — All 5 Entries Populated (Excel)	8.2 — Risk Register	Excel Risk Register
10	Risk Register — Heat Map Tab (Excel Risk Matrix)	9 — Risk Matrix	Excel Risk Register

End of Document